

PLUGIN · v0.1.0

Exposure Audit

Instruction Manual

A scheduled, multi-agent Claude plugin that finds oversharing and misplaced sensitive content across Microsoft 365 (SharePoint / OneDrive / Teams) and Google Workspace (Drive / Gmail) — before someone else's AI agent finds it first.

Why This Exists

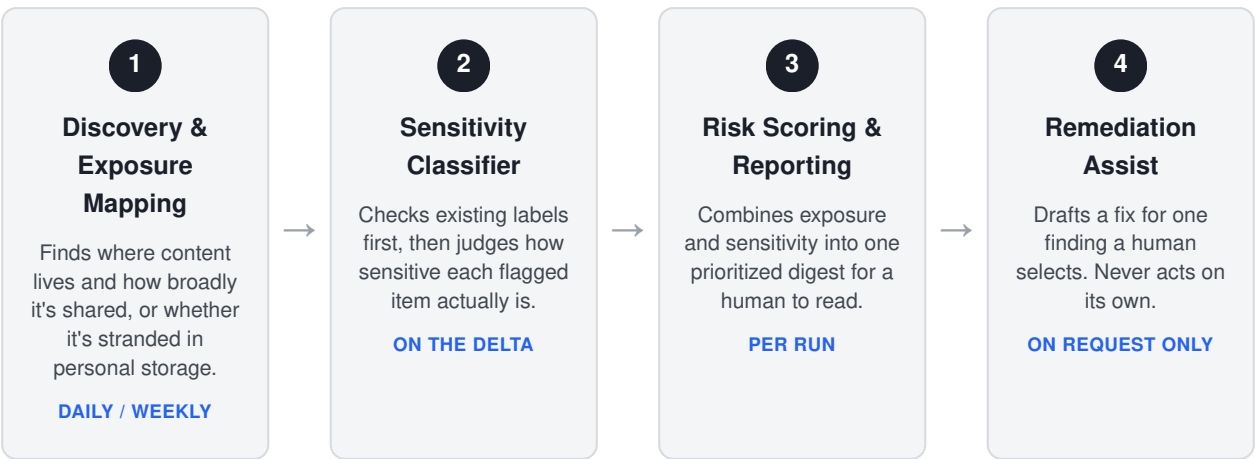
Companies are connecting increasingly capable AI agents — including Claude — to SharePoint and Google Drive. Neither platform's storage model is well understood by most employees: SharePoint, Teams Files, and OneDrive are the same underlying storage with different ownership models, and people routinely misjudge who can see what they upload.

A more capable search agent doesn't create that oversharing. It makes previously-obscure oversharing far easier to actually find — including by people who shouldn't find it. This plugin proactively finds that exposure first, so an organization's own IT or security team can fix it before anyone else does.

Scope, on purpose

This is not a tool for hunting company-specific secrets. It looks for generic categories of sensitive content — the kind that would matter to any organization — and ranks locations by how exposed they are, not by what one particular company considers proprietary.

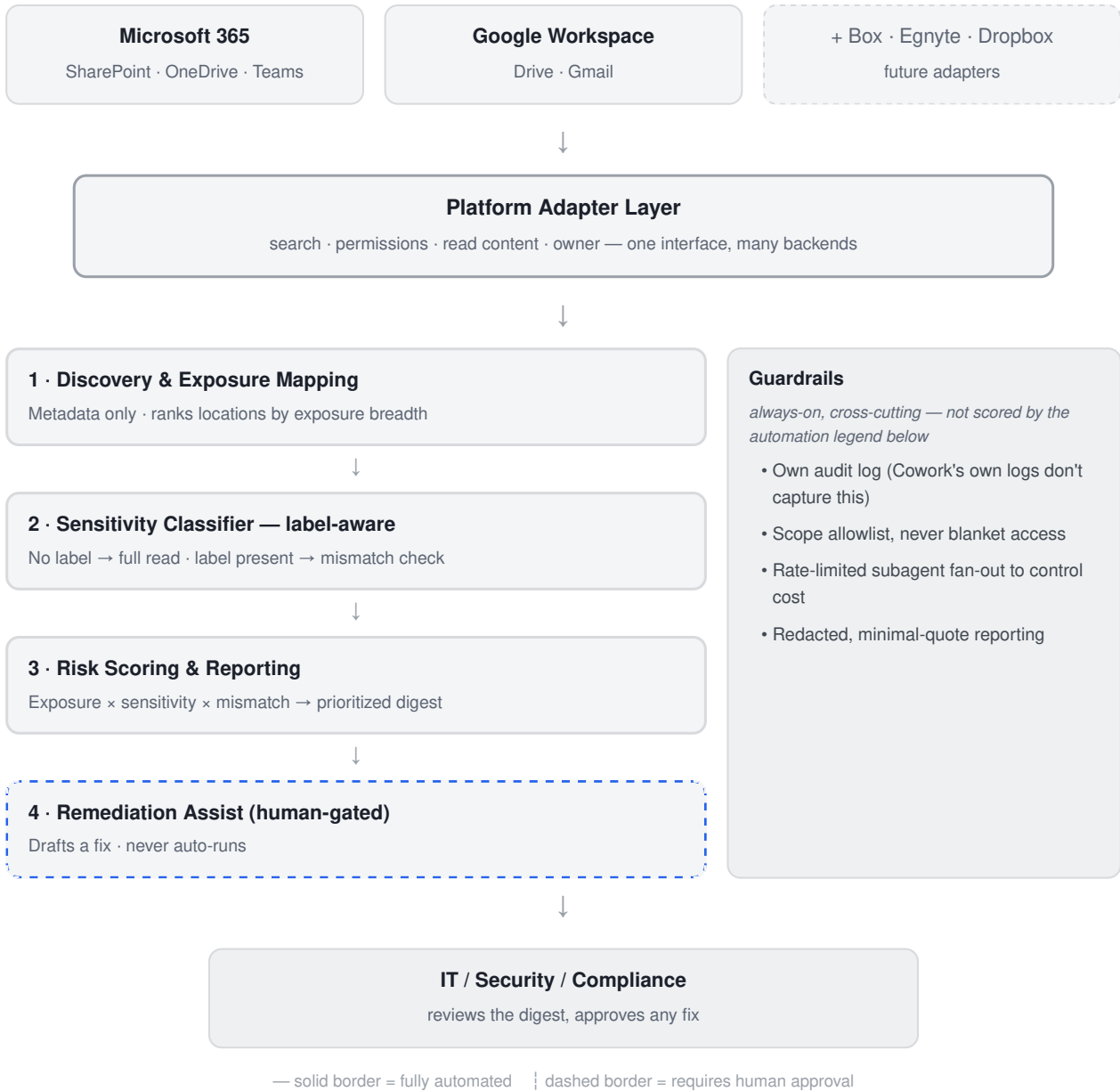
The pipeline at a glance



Stages 1–3 run automatically, in sequence, on a schedule. Stage 4 only ever runs when a person picks a specific finding and asks for a fix — that is a deliberate design choice, not a missing feature (see page on Remediation Assist). The diagram below places these same four stages inside the full data-flow and guardrail context.

System Architecture

The same pipeline runs against either ecosystem through one shared adapter layer — the two platforms are not treated as interchangeable, since they genuinely behave differently (see the limitations table later in this manual).



What Each Skill Does

1 Discovery & Exposure Mapping

Cheap, metadata-only pass across both platforms. Ranks locations by exposure breadth so the expensive stage (2) knows where to spend effort.

Input: connected platform(s), site/drive list

Key logic: one *discovery-scanner* subagent per site/drive, in parallel; flags both *broad/external* sharing and *misplaced* business content in personal storage

Output: ranked candidate list

MULTI-AGENT · FANS OUT

2 Sensitivity Classifier

Determines how sensitive each candidate really is — without blindly trusting labels or blindly re-reading everything.

Input: ranked candidate list from Skill 1

Key logic: one *sensitivity-classifier-worker* subagent per batch; label-first branch (see diagram, next page)

Output: sensitivity level, confidence, mismatch flag

MULTI-AGENT · FANS OUT

3 Risk Scoring & Reporting

Pure synthesis — combines exposure and sensitivity into one coherent, prioritized view. No subagents; one view needs one author.

Input: outputs of Skills 1 & 2

Key logic: scores Critical → High → Medium → Low; always includes a "what we couldn't verify" section

Output: prioritized digest / artifact

SINGLE PASS · NO FAN-OUT

4 Remediation Assist

Drafts one fix for one finding a human explicitly selects. Never runs automatically, never batches, never sends/applies anything itself.

Input: one finding, chosen by a person

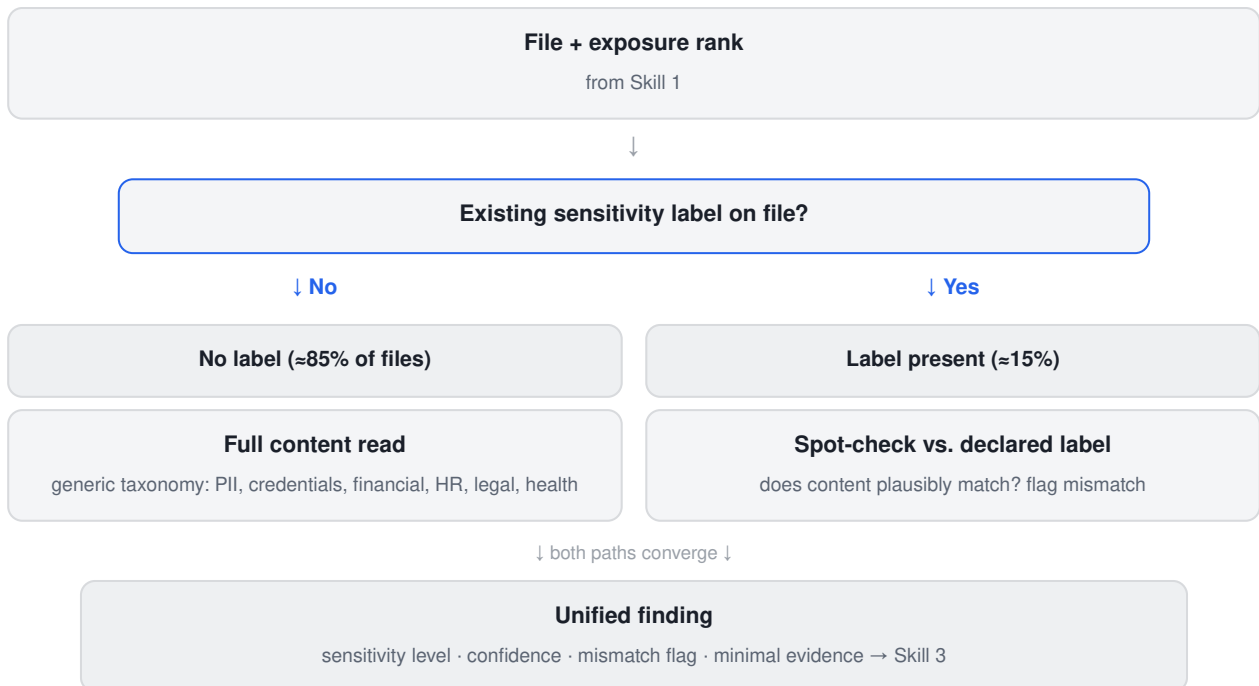
Key logic: drafts an owner notice, a label suggestion, or a permission-change suggestion — always a draft, never an action

Output: a draft, for a human to send

HUMAN-GATED · ON REQUEST ONLY

Inside Skill 2: the label-aware branch

Both Microsoft 365 and Google Workspace already have native sensitivity-tagging systems, but audits of real tenants repeatedly find fewer than 15% of documents actually labeled. So Skill 2 checks for a label first, then does different work depending on what it finds:



Setup

Connect at least one of: a Microsoft 365 connector (SharePoint search) or a Google Workspace connector (Drive search + permissions). Both together is stronger than either alone, since the two platforms cover different parts of a typical company's storage — and, as the limitations below explain, they give this plugin different quality of signal.

To run unattended, wire the `/scan-oversharing` command to a scheduled task. Run it manually first to confirm the connectors and scope are set up the way you expect.

Forgotten what this plugin is for, or whether it's the right tool for something? Just ask — questions like "should I use this for X" or "what are its limits" trigger the bundled `plugin-guide` skill, which answers conversationally without you needing to reopen this manual.

Known Limitations — Read Before Relying On This

MS365 permissions	The current SharePoint connector cannot read real sharing/permission metadata. Discovery falls back to a location heuristic (shared library vs. personal OneDrive) — a reasonable proxy, not a measurement. The ground truth requires SharePoint Admin Center's Data Access Governance reports or the Graph /permissions API with admin consent.
Google Workspace permissions	Real measurement, not an inference — the connector reads actual sharing scope directly. Don't treat the two platforms' outputs as equally precise.
Scope	The connector uses the logged-in user's own delegated access, not a service account. One person's scan covers their own reachable slice of the tenant, not necessarily the whole organization.
Audit trail	The bundled audit-log hook is best-effort, not compliance-grade. It does not replace SOC 2 / HIPAA-grade logging, and Cowork's own audit logs don't currently capture this kind of scheduled agent work either.
Cost	Multi-agent fan-out costs meaningfully more tokens than a single-threaded scan. Each skill bounds its own parallelism deliberately rather than maximizing concurrency.

Design Principles

Report, never auto-remediate

Every write-type action is a draft a human explicitly approves. A scheduled agent that reads files and acts unattended is exactly the shape of a known prompt-injection attack pattern — this plugin is built to never look like one.

Two exposure patterns, not one

Classic oversharing (too many people can see it) and misplacement (too few systems protect it — business-critical content stranded in someone's personal storage, gone the day they leave).

Label-aware, not blind

Check for an existing sensitivity label before doing an expensive full content read, and treat a mismatched label as its own high-value finding rather than folding it into a generic "sensitive" bucket.

Further Reading

Official documentation this plugin's design leans on — useful for verifying a finding by hand, or for tightening the underlying platform's own controls rather than just detecting the gap.

Microsoft 365 / Purview

[Learn about sensitivity labels](#)

learn.microsoft.com/en-us/purview/sensitivity-labels

[Enable sensitivity labels for SharePoint and OneDrive files](#)

learn.microsoft.com/en-us/purview/sensitivity-labels-sharepoint-onedrive-files

[Data access governance reports for SharePoint sites — the real oversharing/permission snapshot this plugin's MS365 side can only infer](#)

learn.microsoft.com/en-us/sharepoint/data-access-governance-reports

[Microsoft Graph — list a DriveItem's real permissions](#)

learn.microsoft.com/en-us/graph/api/driveitem-list-permissions

Google Workspace

[About data loss prevention \(DLP\) for Drive](#)

knowledge.workspace.google.com/admin/security/about-dlp

[Create classification labels for your organization](#)

knowledge.workspace.google.com/admin/security/create-classification-labels-for-your-organization

[Apply classification labels to Drive files automatically with DLP rules](#)

knowledge.workspace.google.com/admin/security/apply-classification-labels-to-drive-files-automatically-with-dlp-rules

Vendor-neutral

[NIST SP 1800-39 — Data Classification Practices](#)

nccoe.nist.gov/data-classification